

Incident Response Playbook for Mitigating Phishing Attacks at M[REDACTED]re

Introduction

Phishing remains one of the most common cyber threats affecting healthcare organisations. A successful phishing attack can result in the theft of sensitive patient information, disruption of clinical services, financial loss, and damage to an organisation's reputation. As a healthcare provider, M[REDACTED]re handles confidential patient records and other critical information, making it an attractive target for cybercriminals.

This Incident Response Playbook provides a structured approach for preparing for, detecting, responding to, recovering from, and learning from phishing incidents. It establishes clear responsibilities for key stakeholders, outlines the actions required at each stage of the incident response lifecycle, and promotes consistent decision-making during security incidents.

The objectives of this playbook are to minimise the impact of phishing attacks, protect patient data and business operations, ensure regulatory compliance, and strengthen M[REDACTED]'s overall cyber resilience through continuous improvement.

1. Planning and Preparation

The planning phase focuses on ensuring we prepared before a phishing incident occurs.

Incident Response Team

Establish a Core Incident Response Team and clearly define responsibilities for key personnel, including:

- Incident Response Manager
- Vulnerability Manager
- Threat Intelligence Manager
- Risk Manager
- The Core Incident Response Team is responsible for maintaining and reviewing the Cyber Incident Response Process and ensuring that response procedures remain current.

– Preventive Measures

- The team should:
- Maintain incident response timelines and escalation procedures.
- Define approved email communication methods and reporting protocols.
- Identify high-value phishing targets such as executives, finance personnel, and Heads of Departments.

- Define phishing indicators and educate employees on both traditional and emerging phishing techniques.
- Establish clear procedures for reporting suspicious emails.

Technical Security Controls

Implement technical safeguards including:

- DMARC
- SPF
- DKIM
- S/MIME
- Anti-phishing email security solutions

Additional preventive measures include:

- Conduct regular security awareness training and simulated phishing exercises.
- Implement Multi-Factor Authentication (MFA) for critical systems.
- Apply M of N approval controls for high-risk business transactions requiring multiple authorised approvers.
- Continuously monitor threat intelligence feeds and block known malicious IP addresses, domains and URLs through firewall policies.
- Configure execution policies that prevent unauthorised executable files from running on user devices.

2. Detection

Detection activities include:

- Centralised log collection and monitoring from endpoints, servers, email systems and network devices using a SIEM platform.
- Configure automated alerts and response actions where appropriate.
- Deploy security monitoring technologies such as:
 - Intrusion Detection Systems (IDS)
 - Firewalls
 - Antivirus software
 - Vulnerability scanners
 - Spam filtering solutions

Potential phishing incidents may also be identified through:

- Employee reports of suspicious or spoofed emails.
- Emails containing unfamiliar or suspicious links and attachments.
- Notifications from customers, business partners or law enforcement.
- Network monitoring that identifies communication with unknown or malicious IP addresses.
- Inspection of email headers, metadata, embedded links and URLs using email analysis tools.

3. Analysis

Analysis activities include:

- Compare phishing emails against known Indicators of Compromise (IOCs).
- Triage alerts to eliminate false positives.
- Identify the intended targets, such as users, databases, servers or executive staff.
- Determine whether the attack is a mass phishing campaign, spear-phishing or whaling attempt.
- Assess whether users clicked links, opened attachments or disclosed credentials.
- Identify any established communication between compromised systems and attacker infrastructure.
- Safely analyse suspicious links and attachments in isolated, non-production environments.
- Classify the incident based on its potential impact on patient care, confidentiality, operations and business continuity.

4. Containment

Containment actions include:

- Immediately isolate affected endpoints from the network.
- Use network segmentation to isolate affected VLANs, servers or network segments.
- Quarantine phishing emails to prevent further delivery within the organisation.
- Disable compromised user accounts and revoke active sessions.
- Prevent attackers from using stolen credentials for privilege escalation or lateral movement.

5. Recovery

Recovery actions include:

- Terminate malicious processes initiated through compromised accounts.
- Remove phishing emails and malicious links from mail servers.
- Work with authorised third-party takedown services to remove fraudulent websites or phishing domains impersonating Medline.
- Verify that all malicious files, accounts and persistence mechanisms have been eradicated.
- Test affected systems before returning them to production.
- Continue monitoring for any signs of recurring malicious activity.

6. Lessons Learned

- Perform a Root Cause Analysis to determine how the phishing attack succeeded.
- Document findings and recommendations.
- Update incident response procedures where improvements are identified.
- Enhance detection capabilities by updating signatures, indicators and behavioural detection rules, including AI and User and Entity Behaviour Analytics (UEBA) where appropriate.

- Improve employee awareness training and phishing simulations using lessons learned from the incident.
- Share relevant findings with stakeholders to strengthen organisational resilience.

7. Governance

- Assign ownership of each phase of the incident response process to designated stakeholders.
- Monitor compliance with organisational security policies and regulatory requirements.
- Ensure incident reporting deadlines are achieved.
- Support continuous monitoring, regular process reviews and effective management of personnel involved in incident response.